

Marco integrativo GQM + PRAGMATIC para indicadores HyVAW

1. Introducción

El propósito de este marco es asegurar que cada indicador derivado de HyVAW y utilizado a nivel nacional (España) esté trazado desde metas estratégicas hasta datos técnicos mediante la metodología Goal-Question-Metric (GQM), y que cada métrica sea críticamente evaluada con los criterios PRAGMATIC (Predictive, Relevant, Actionable, Genuine, Meaningful, Accurate, Timely, Independent, Cost-effective).[web:3][web:16][web:23][web:36][web:43][web:48]

GQM aporta la estructura de descomposición “de arriba abajo”: metas → preguntas → métricas.[web:43][web:45] PRAGMATIC aporta el filtro “de calidad de métricas”, separando los números útiles de la decoración anecdótica.[web:42][web:44][web:48]

2. Metas nacionales HyVAW y contexto NIS2

A partir del informe HyVAW y del contexto NIS2/ENISA, podemos sintetizar cuatro metas nacionales de alto nivel:[web:3][web:16][web:18][web:23][web:36]

- G1 – Cobertura: Aumentar la cobertura de análisis híbrido de vulnerabilidades (HyVAW o equivalente) sobre los sistemas esenciales de operadores españoles regulados por NIS2.
- G2 – Calidad del análisis: Mejorar la calidad y eficacia del análisis híbrido, reduciendo falsos positivos y aumentando la detección de vulnerabilidades críticas reales.
- G3 – Gestión y resiliencia: Reducir el riesgo operativo asociado a vulnerabilidades conocidas mediante tiempos de remediación adecuados y priorización alineada con NIS2.
- G4 – Valor y sostenibilidad: Garantizar que las inversiones en HyVAW y gestión de vulnerabilidades producen beneficios tangibles (reducción de incidentes, cumplimiento, ROI).

Estas metas se apoyan en las exigencias de NIS2 en materia de gestión de riesgos, medidas técnicas y organizativas, y supervisión, así como en la guía técnica de ENISA que propone evidencias e indicadores concretos para demostrar dichas medidas.[web:18][web:23][web:36]

3. Aplicación de GQM a los indicadores HyVAW

3.1. G1 – Cobertura de análisis híbrido

Goal G1: Analizar y mejorar el grado de cobertura de análisis híbrido de vulnerabilidades sobre los sistemas esenciales para reducir zonas ciegas y elevar la madurez nacional.[web:3][web:16][web:23][web:36]

Preguntas G1 (Q1.x)

- Q1.1: ¿Qué porcentaje de sistemas esenciales está sujeto, al menos una vez al año, a un flujo de análisis híbrido (HyVAW o equivalente)?
- Q1.2: ¿En qué medida la cobertura de análisis coincide con el inventario de activos críticos declarado

bajo NIS2?

- Q1.3: ¿Qué sectores y tamaños de organización presentan las mayores brechas de cobertura?

Métricas G1 (M1.x)

- M1.1 – % de sistemas esenciales con análisis híbrido anual:

(%) de sistemas esenciales que han sido analizados mediante un flujo que combina al menos tres tipos de análisis (estático, dinámico, pruebas manuales, etc.) en los últimos 12 meses.[web:3][web:8][web:19]

•

M1.2 – Índice de cobertura de activos críticos:

Proporción de activos críticos (según inventario NIS2) cubiertos por análisis híbrido frente al total de activos críticos declarados.[web:23][web:36]

•

M1.3 – Distribución sectorial/tamaño de la cobertura:

Mapa de M1.1 y M1.2 por sector NIS2 y categoría de tamaño, para identificar brechas estructurales.
[web:21][web:32][web:36]

M1.2 – Índice de cobertura de activos críticos:

Proporción de activos críticos (según inventario NIS2) cubiertos por análisis híbrido frente al total de activos críticos declarados.[web:23][web:36]

M1.3 – Distribución sectorial/tamaño de la cobertura:

Mapa de M1.1 y M1.2 por sector NIS2 y categoría de tamaño, para identificar brechas estructurales.
[web:21][web:32][web:36]

3.2. G2 – Calidad del análisis híbrido

Goal G2: Evaluar y mejorar la calidad de los flujos híbridos de análisis (HyVAW), minimizando falsos positivos e incrementando la detección de vulnerabilidades críticas confirmadas.[web:3][web:8]
[web:24]

Preguntas G2 (Q2.x)

- Q2.1: ¿Cuál es la tasa de falsos positivos en vulnerabilidades críticas y altas?

- Q2.2: ¿Qué porcentaje de vulnerabilidades críticas detectadas se confirma mediante análisis dinámico o pruebas manuales?

- Q2.3: ¿Qué profundidad media tienen los análisis en términos de número de fases aplicadas por vulnerabilidad confirmada?

Métricas G2 (M2.x)

- M2.1 – Tasa de falsos positivos críticos:

Número de vulnerabilidades críticas inicialmente detectadas y posteriormente clasificadas como falsos positivos / número total de vulnerabilidades críticas detectadas.[web:8][web:19][web:24]

- M2.2 – Proporción de vulnerabilidades críticas confirmadas dinámicamente:
Vulnerabilidades críticas con confirmación mediante análisis dinámico o pruebas manuales / total de vulnerabilidades críticas detectadas.[web:8][web:24]
- M2.3 – Fases por vulnerabilidad confirmada:
Número medio de fases diferentes (estático, dinámico, manual, emulación, etc.) aplicadas por cada vulnerabilidad crítica confirmada.[web:3][web:8][web:24]

M2.2 – Proporción de vulnerabilidades críticas confirmadas dinámicamente:

Vulnerabilidades críticas con confirmación mediante análisis dinámico o pruebas manuales / total de vulnerabilidades críticas detectadas.[web:8][web:24]

M2.3 – Fases por vulnerabilidad confirmada:

Número medio de fases diferentes (estático, dinámico, manual, emulación, etc.) aplicadas por cada vulnerabilidad crítica confirmada.[web:3][web:8][web:24]

3.3. G3 – Gestión y resiliencia

Goal G3: Reducir el riesgo residual derivado de vulnerabilidades conocidas mediante tiempos de remediación adecuados, priorización basada en riesgo y correlación con incidentes.[web:19][web:23][web:32][web:36]

Preguntas G3 (Q3.x)

- Q3.1: ¿Cuál es el tiempo medio de remediación (TTR) para vulnerabilidades críticas y altas en servicios esenciales?
- Q3.2: ¿Qué porcentaje de vulnerabilidades se resuelve dentro de los plazos objetivo definidos (por normativa o internamente)?
- Q3.3: ¿Con qué frecuencia se producen incidentes derivados de vulnerabilidades previamente identificadas?

Métricas G3 (M3.x)

- M3.1 – TTR vulnerabilidades críticas:
Tiempo medio (en días) desde la detección hasta el cierre efectivo de vulnerabilidades críticas en sistemas esenciales.[web:19][web:23][web:32]

- M3.2 – Cumplimiento de plazos de remediación:
% de vulnerabilidades críticas y altas cerradas dentro del plazo objetivo (por ejemplo, ≤30 días para críticas).[web:23][web:36]
- M3.3 – Incidentes por vulnerabilidad conocida:
Número de incidentes significativos en los que la vulnerabilidad explotada estaba previamente identificada / número total de incidentes significativos.[web:32][web:34]

M3.2 – Cumplimiento de plazos de remediación:

% de vulnerabilidades críticas y altas cerradas dentro del plazo objetivo (por ejemplo, ≤30 días para críticas).[web:23][web:36]

M3.3 – Incidentes por vulnerabilidad conocida:

Número de incidentes significativos en los que la vulnerabilidad explotada estaba previamente identificada / número total de incidentes significativos.[web:32][web:34]

3.4. G4 – Valor y sostenibilidad (ROI)

Goal G4: Evaluar el retorno de la inversión en análisis híbrido de vulnerabilidades (HyVAW) y su contribución a la reducción de impacto y al cumplimiento regulatorio.[web:19][web:23][web:32][web:48]

Preguntas G4 (Q4.x)

- Q4.1: ¿Cuál es el coste anual directo de las actividades de análisis híbrido de vulnerabilidades?
- Q4.2: ¿En qué medida se han reducido los incidentes significativos tras la implantación de HyVAW?
- Q4.3: ¿Qué reducción de impacto económico (pérdidas evitadas, multas evitadas) puede atribuirse razonablemente a HyVAW?

Métricas G4 (M4.x)

- M4.1 – Coste anual HyVAW por sistema esencial:

Coste total anual de herramientas, servicios y personal dedicado a análisis híbrido dividido por número de sistemas esenciales cubiertos.[web:19][web:23]

- M4.2 – Reducción de incidentes significativos:
(Incidentes significativos promedio anual antes de HyVAW – incidentes significativos después) /
incidentes antes.[web:19][web:32][web:34]
- M4.3 – ROI HyVAW aproximado:
(Impacto evitado estimado + ahorro en indisponibilidad – coste anual HyVAW) / coste anual
HyVAW.[web:19][web:48]

M4.2 – Reducción de incidentes significativos:

(Incidentes significativos promedio anual antes de HyVAW – incidentes significativos después) /
incidentes antes.[web:19][web:32][web:34]

M4.3 – ROI HyVAW aproximado:

(Impacto evitado estimado + ahorro en indisponibilidad – coste anual HyVAW) / coste anual HyVAW.
[web:19][web:48]

4. Evaluación PRAGMATIC de las métricas HyVAW

Para cada métrica M1.x–M4.x, se aplica la matriz PRAGMATIC, puntuando cada criterio en una escala 1–5 (1 = pobre, 5 = excelente), siguiendo la propuesta de Brotby e Hinson.[web:42][web:44][web:48]

Los criterios son:

- P – Predictive (Predictivo): ¿ayuda a anticipar el futuro rendimiento o riesgo?
- R – Relevant (Relevante): ¿está alineada con los objetivos estratégicos (G1–G4)?
- A – Actionable (Accionable): ¿puede generar decisiones y acciones concretas?
- G – Genuine (Genuino): ¿refleja la realidad, sin manipulación fácil ni cosmética?
- M – Meaningful (Significativo): ¿es comprensible y significativo para stakeholders clave?
- A – Accurate (Preciso): ¿es suficientemente exacta para su propósito?
- T – Timely (Oportuno): ¿puede obtenerse y actualizarse con una frecuencia adecuada?
- I – Independent (Independiente): ¿no está excesivamente sesgada por intereses de parte?
- C – Cost-effective (Rentable / Cheap): ¿el coste de medirla es razonable respecto al valor?[web:42][web:44][web:48]

La “Matriz de Evaluación PRAGMATIC Completa” desarrolla estas puntuaciones y justificaciones para cada métrica.

5. Integración práctica en el programa nacional

Operativamente, este marco permite:

1. Definir un catálogo nacional de métricas HyVAW-NIS2 con trazabilidad GQM.
2. Evaluar periódicamente la calidad de cada métrica con PRAGMATIC y depurar el catálogo (retirar métricas pobres, priorizar las excelentes).[web:43][web:48]
3. Alinear la encuesta HyVAW, el Excel de IGM/ROI y los informes ejecutivos con este modelo para mantener coherencia de arriba abajo.[web:23][web:36]

Con ello, el país evita dos extremos igual de poco saludables: medirlo todo sin saber para qué, o no medir casi nada y fiarse del instinto. GQM pone los objetivos; PRAGMATIC decide si las métricas valen el esfuerzo.